



NIVEAU 3

IMPLEMENTIERUNG: DATENSCHUTZVERLETZUNG, ÜBERMITTLUNGEN UND VERTRAG ZUR AUFTRAGSVERARBEITUNG

Schlüsselwörter: Anonymisierung, Datenschutzverletzung, Verzeichnis für Datenschutzverletzungen, Verschlüsselung, Vertraulichkeit, Auftragsverarbeitungsvertrag, Information der betroffenen Personen, Haftung, Benachrichtigung, personenbezogene Daten der Mitarbeiter, Pseudonymisierung, Rechte und Freiheiten der betroffenen Personen, Risiken, Standardvertragsklauseln, technische und organisatorische Sicherheitsmaßnahmen, Drittländer, Übermittlungen



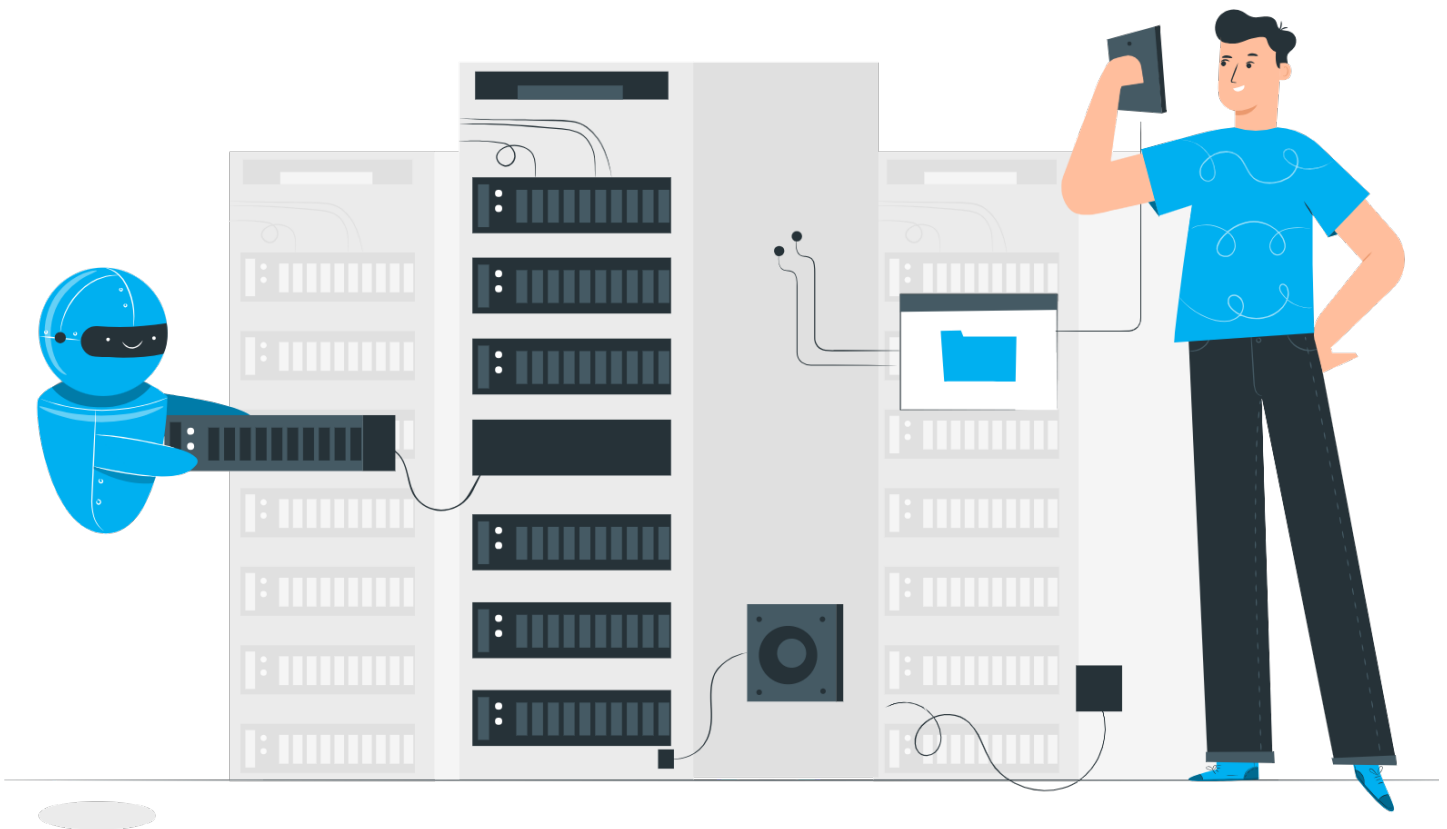
LHC
Luxembourg House
of Cybersecurity



National Commission
for Data Protection
Grand-Duchy of Luxembourg



Co-funded by the
European Union



GUT ZU WISSEN

Luxembourg House of Cybersecurity (LHC)

Das LHC ist das Rückgrat der hochmodernen Cyberresilienz in Luxemburg und zielt darauf ab, Innovation, Kompetenzen, Zusammenarbeit und Kapazitätsaufbau zu nutzen, weiterzuentwickeln und zu fördern. Als zentraler Akteur beherbergt das LHC alle Arten von Aktivitäten rund um die Cybersicherheit. Mit seinen beiden Zentren CIRCL (Computer Incident Response Center Luxembourg) und NC3 (National Cybersecurity Competence Center) und mit seinen Partnern unterstützt, fördert und bedient LHC eine Vielzahl von Sektoren wie zum Beispiel den öffentlichen Dienst, den Privatsektor, das Gesundheitswesen, den Bildungssektor oder die Industrie.

Computer Incident Response Center Luxembourg

CIRCL ist eine Regierungsinitiative, die entwickelt wurde, um Computersicherheitsbedrohungen und -vorfälle zu sammeln, zu überprüfen, zu melden und darauf zu reagieren. CIRCL bietet eine zuverlässige und vertrauenswürdige Anlaufstelle für alle Benutzer, Unternehmen und Organisationen mit Sitz in Luxemburg, für den Umgang mit Angriffen und Vorfällen. Ziel von CIRCL ist es, Cyberbedrohungen systematisch und zeitnah zu erfassen, zu untersuchen, zu melden und darauf zu reagieren.

WIE REAGIEREN IM FALLE EINER DATENSCHUTZVERLETZUNG?

1. Data breach concepts

What is a data breach?

A personal data breach is a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to, personal data transmitted, stored or otherwise processed.

Data breaches can be categorized according to the three well-known principles of information security:

- **Breach of confidentiality:** en cas de divulgation ou d'accès non autorisé ou accidentel à des données à caractère personnel
- **Breach of availability** in case of loss /accidental or unauthorized destruction of personal data
- **Integrity breach** : in case of accidental or unauthorized modification of personal data

Depending on the circumstances, a breach may concern the confidentiality, the integrity and the availability at the same time, as well as any combination of these three principles.

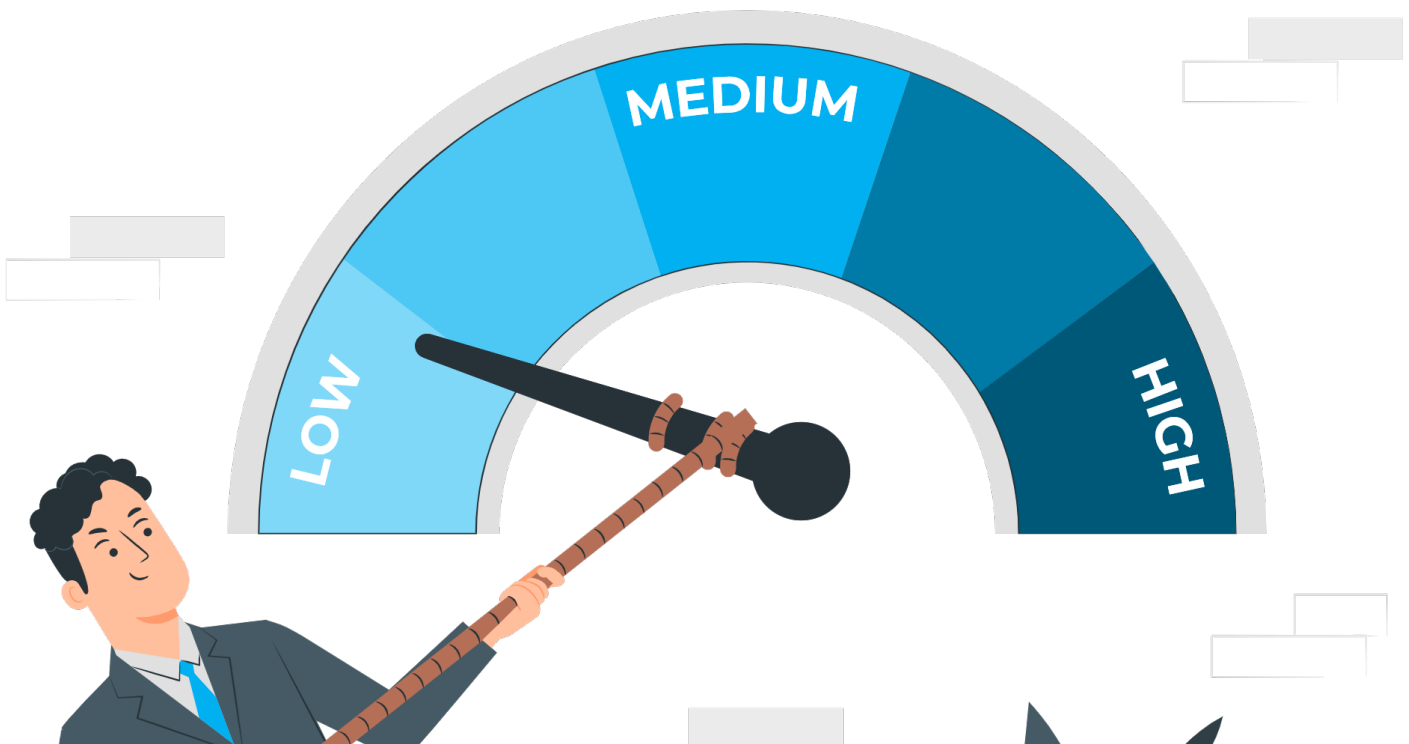
Recital 85 GDPR: A personal data breach may, if not addressed in an appropriate and timely manner, result in physical, material

or non-material damage to natural persons such as loss of control over their personal data or limitation of their rights, discrimination, identity theft or fraud, financial loss, unauthorised reversal of pseudonymisation, damage to reputation, loss of confidentiality of personal data protected by professional secrecy or any other significant economic or social disadvantage to the natural person concerned.

What to do in the event of a data breach?

The controller shall identify whether the data breach presents a risk to the rights and freedoms of the data subjects. Controllers may use their replies to notification form as a basis for determining whether the breach poses a risk to data subjects.





Wann und wie ist die CNPD zu benachrichtigen?

Führt die Datenschutzverletzung zu einem Risiko für die Rechte und Freiheiten von den betroffenen Personen, ist eine Benachrichtigung der CNPD innerhalb von 72 Stunden nach Kenntnisnahme erforderlich.

Das Meldeformular der CNPD kann für die Benachrichtigung verwendet werden.

Die Meldung muss mindestens:

1. Die Art / Natur der Datenschutzverletzung beschreiben, einschließlich, soweit möglich, der Kategorien und der (geschätzten) Anzahl der betroffenen Personen und der Datenkategorien sowie der geschätzten Anzahl der betroffenen Datensätze;
2. den Namen und die Kontaktdaten des Datenschutzbeauftragten oder einer anderen Kontaktstelle enthalten, bei der weitere Informationen eingeholt werden können;
3. die wahrscheinlichen Folgen der Datenschutzverletzung beschreiben;
4. die vom Verantwortlichen ergriffenen oder vorgeschlagenen Maßnahmen zur Behebung der Datenschutzverletzung beschreiben,

5. gegebenenfalls einschließlich Maßnahmen zur Abmilderung ihrer möglichen nachteiligen Auswirkungen.

Die Meldung über den Verstoß ist an die E-Mail-Adresse databreach@cnpd.lu zu senden. Sie können den öffentlichen gpg-Schlüssel zum Herunterladen verwenden, um die Übertragung von Informationen zu verschlüsseln.

GUT ZU WISSEN:

Das Risiko wird unter anderem durch den Grad der Sensibilität der verarbeiteten Daten sowie die Schwere und Wahrscheinlichkeit der Auswirkungen auf die Grundrechte und Grundfreiheiten der betroffenen Personen (körperliche, materielle, moralische Auswirkungen usw.) definiert. Zum Beispiel erfordert die Verwaltung der Mitglieder eines gemeinnützigen Vereins ein geringeres Maß an Sicherheit als die Verwaltung medizinischer Akten durch einen Arzt.

GUT ZU WISSEN:

Der Verweis auf die Grundrechte und Grundfreiheiten natürlicher Personen bezieht sich hauptsächlich auf den Datenschutz und den Schutz der Privatsphäre, erstreckt sich aber gegebenenfalls auch auf andere Grundrechte wie etwa die Meinungsfreiheit, Gedankenfreiheit, die Bewegungsfreiheit, das Diskriminierungsverbot, Recht auf Freiheit und Gewissens- und Religionsfreiheit.

Wann und wie müssen die betroffenen Personen über die Datenschutzverletzung informiert werden?

Wenn die Verletzung des Schutzes personenbezogener Daten voraussichtlich zu einem hohen Risiko für die Rechte und Freiheiten natürlicher Personen führt, meldet der Verantwortliche den betroffenen Personen die Verletzung des Schutzes personenbezogener Daten unverzüglich.

Die Mitteilung an die betroffene Person muss in klarer und einfacher Sprache die Art der Verletzung des Schutzes personenbezogener Daten beschreiben und mindestens Folgendes enthalten:

1. Name und Kontaktdaten des Datenschutzbeauftragten oder einer sonstigen Anlaufstelle, bei der weitere Informationen eingeholt werden können;
2. eine Beschreibung der wahrscheinlichen Folgen der Verletzung des Schutzes personenbezogener Daten;
3. eine Beschreibung der vom Verantwortlichen ergriffenen der vorgeschlagenen Maßnahmen zur Behebung der Verletzung des Schutzes personenbezogener Daten und gegebenenfalls Maßnahmen zur Abmilderung ihrer möglichen nachteiligen Auswirkungen.

Die für die Kontaktaufnahme mit den betroffenen Personen verwendeten Kommunikationsmittel müssen wirksam sein, d. h. es muss sichergestellt werden, dass die betroffenen Personen die übermittelten Informationen mit hoher Wahrscheinlichkeit erhalten. Gegebenenfalls kann eine öffentliche Kommunikation erforderlich sein.

Führen Sie ein Verzeichnis der Datenschutzverletzungen

Unabhängig davon, ob das Risiko hoch, vorhanden oder nicht vorhanden ist, muss der Datenverantwortliche jede Verletzung des Schutzes personenbezogener Daten dokumentieren unter Angabe der Fakten in Bezug auf die Verletzung des Schutzes personenbezogener Daten, ihrer Auswirkungen und der zu ihrer Behebung ergriffenen Maßnahmen (auch derjenigen, die nicht der CNPD gemeldet werden müssen).

Die CNPD kann Zugang zu diesen Unterlagen beantragen, um die Einhaltung der DSGVO durch den Verantwortlichen oder den Auftragsverarbeiter zu überprüfen.

Was wird die CNPD nach Eingang der Meldung tun?

Sobald die Mitteilung eingegangen ist, wird die CNPD:

- eine elektronische Empfangsbestätigung senden (an dieselbe Adresse, von der die Meldung abgeschickt wurde);
- die Meldung überprüfen und sich erforderlichenfalls an den Verantwortlichen wenden, um die Informationen in der Meldung zu überprüfen;
- sich bei Fragen unter Umständen an den Verantwortlichen wenden – einschließlich der Frage zur Notwendigkeit, die betroffenen Personen zu informieren oder nicht.

Die Bearbeitung der Meldung durch die CNPD wird sich stark auf die Bewältigung des Vorfalls durch den Verantwortlichen und gegebenenfalls auf die Mitteilung an die betroffenen Personen konzentrieren.



Verantwortlichkeiten der Auftragsverarbeiter

Auftragsverarbeiter sind dafür verantwortlich, organisatorische und technische Maßnahmen zu ergreifen, um den/die Verantwortlichen so schnell wie möglich über einen Vorfall mit personenbezogenen Daten zu informieren, damit der/die Verantwortliche(n) die Benachrichtigungsfrist von 72 Stunden nach Feststellung des Vorfalls einhalten kann/können.

Was tun nach der Datenschutzverletzung?

Es ist wichtig, dass ein Unternehmen die organisatorischen und technischen Sicherheitsmaßnahmen an seine Verarbeitungstätigkeiten anpasst, um zu verhindern, dass die gleiche Art von Verstoß erneut auftritt.

Vertraulichkeit des Verstoßes

Es liegt nicht in der Zuständigkeit der CNPD, eine Datenschutzverletzung öffentlich zu machen. Ein Verantwortlicher kann jedoch durch seinen eigenen Beschluss oder auf Antrag der Nationalen Kommission öffentlich über eine Datenschutzverletzung informieren, wenn diese wahrscheinlich zu einem Risiko für die Rechte und Freiheiten natürlicher Personen führt und wenn diese Personen nicht auf andere Weise wirksam kontaktiert werden können.





2.2. Technische und organisatorische Maßnahmen

Gewährleistung eines dem Risiko angemessenen Sicherheitsniveaus

Eine der Anforderungen der DSGVO besteht darin, dass personenbezogene Daten so verarbeitet werden, dass ein angemessenes Maß an Sicherheit dieser Daten gewährleistet ist, und insbesondere, dass sie durch geeignete technische oder organisatorische Maßnahmen vor unbefugter oder unrechtmäßiger Verarbeitung sowie vor unbeabsichtigtem Verlust, unbeabsichtigter Zerstörung oder unbeabsichtigter Beschädigung geschützt sind.

Die DSGVO schreibt daher vor, dass Verantwortliche und Auftragsverarbeiter geeignete technische und organisatorische Maßnahmen ergreifen müssen, um ein dem Risiko für die verarbeiteten personenbezogenen Daten angemessenes Sicherheitsniveau zu gewährleisten. Sie sollten den Stand der Technik, die Implementierungskosten und die Art, den Umfang, den Kontext und die Zwecke der

Verarbeitung sowie die Risiken berücksichtigen, die sich aus der Verarbeitung für die Rechte und Freiheiten natürlicher Personen ergeben, wobei die Wahrscheinlichkeit und der Schweregrad variieren. Die DSGVO verlangt auch, dass alle geeigneten technischen und organisatorischen Sicherheitsvorkehrungen getroffen werden, um sofort festzustellen, ob eine Verletzung des Schutzes personenbezogener Daten vorliegt, die darüber entscheidet, ob die Meldepflicht gilt.

Nach einem Vorfall ist es wichtig, dass ein Unternehmen die organisatorischen und technischen Sicherheitsmaßnahmen, die seine Verarbeitungsvorgänge betreffen, anpasst, um ein erneutes Auftreten derselben Art von Verstößen zu verhindern.

Abbildungen von Sicherheitsmaßnahmen

- **Verschlüsselung**

Die Verschlüsselung übersetzt Daten in eine andere Form oder einen anderen Code, so dass nur Personen mit Zugriff auf einen geheimen Schlüssel oder ein Passwort ihn lesen können. Verschlüsselte Daten werden üblicherweise als Chiffretext bezeichnet, während unverschlüsselte Daten als Klartextdaten bezeichnet werden.

Derzeit ist Verschlüsselung eine der beliebtesten und effektivsten Datensicherheitsmethoden, die von Unternehmen verwendet werden. Der aktuelle Stand der Technik muss berücksichtigt werden, denn eine veraltete Technologie ist ungültig.

- **Pseudonymisierung**

Pseudonymisierung besteht darin, direkt identifizierende Daten (Nachname, Vornamen usw.) in einem Datensatz durch indirekt identifizierende Daten (Alias, fortlaufende Nummer usw.) zu ersetzen. Die Pseudonymisierung ermöglicht es somit, die Daten von Personen zu verarbeiten, ohne sie direkt identifizieren zu können. Im Gegensatz zur Anonymisierung ist die Pseudonymisierung eine reversible Operation: Es ist möglich, die Identität einer Person wiederherzustellen, wenn zusätzliche Informationen verfügbar sind.

- **Anonymisierung**

Anonymisierung ist die Verarbeitung personenbezogener Daten in einer Weise, die es praktisch unmöglich macht, die betroffene Person auf irgendeine Weise wieder zu identifizieren. Dieser Vorgang ist irreversibel, so dass es nicht mehr möglich ist, die Identität einer Person nachzuvollziehen.

Die Anonymisierung eröffnet das Potenzial für die Wiederverwendung von Daten und ermöglicht es den Akteuren, ihren "Datenbestände" zu nutzen und zu teilen, ohne die Privatsphäre der Menschen zu verletzen. Es ermöglicht auch die Aufbewahrung von Daten ohne Einschränkung.

Es sei darauf hingewiesen, dass Anonymisierung in der Praxis eine Technik ist, die Informationen zerstört. Es ist daher ratsam, Anonymisierung zu verwenden, wenn:

- Ausreichende Datenmengen verfügbar sind;
- Eine klare Vorstellung davon existiert, wie anonymisierte Daten verwendet werden;
- Man in der Lage ist, eine Anonymisierungsmethode zu implementieren, die die gewünschten Eigenschaften des Datensatzes beibehält

Um einen relevanten Anonymisierungsprozess aufzubauen, ist es ratsam:

- Die zu anonymisierenden Datenkategorien zu untersuchen (strukturierte oder unstrukturierte Daten, Zeitreihen, Geolokalisierungsinformationen usw.);
- Direkte Identifikatoren sowie seltene Werte, die eine einfache Neuidentifizierung von Personen ermöglichen könnten, zu entfernen (z.B. kann die genaue Kenntnis des Alters der in einem Datensatz vorhandenen Personen in bestimmten Fällen die Neuidentifizierung von Hundertjährigen sehr einfach machen);
- Zwischen wichtigen und sekundären oder nutzlosen Informationen zu unterscheiden (d.h. löschbaren Informationen, die nach dem Grundsatz der Datenminimierung am besten überhaupt nicht erfasst werden);
- Den idealen und akzeptablen Detaillierungsgrad für jedes gespeicherte Informationselement zu definieren;
- Prioritäten zu definieren (z.B. ist es wichtiger, einen hohen Detaillierungsgrad für diese Informationen beizubehalten oder andere Informationen beizubehalten?).

Was ist ein Drittland?

Ein Drittland ist ein Land, das nicht an die Datenschutz-Grundverordnung (DSGVO) gebunden ist, im Gegensatz zu den 27 EU-Mitgliedstaaten und den drei Mitgliedstaaten des Europäischen Wirtschaftsraums (EWR), Norwegen, Liechtenstein und Island.

Transfer innerhalb des Europäischen Wirtschaftsraums

Personenbezogene Daten können aus dem Großherzogtum Luxemburg innerhalb des Europäischen Wirtschaftsraums (Europäische Union, Liechtenstein, Norwegen und Island) frei weitergegeben werden, sofern die allgemeinen Grundsätze der DSGVO eingehalten werden.

In der Tat wenden die Mitgliedstaaten bei der Verarbeitung personenbezogener Daten das gleiche Schutzniveau an. Eine Übermittlung innerhalb des Europäischen Wirtschaftsraums ist daher genauso geregelt wie eine Übermittlung nach Luxemburg und muss daher den allgemeinen Grundsätzen der DSGVO entsprechen (insbesondere der Einhaltung des Grundsatzes der Rechtmäßigkeit, der Vereinbarkeit der Kommunikation mit der ursprünglichen Verarbeitung, der Information der betroffenen Personen).

Übermittlung in ein Drittland, das einen anerkannten angemessenen Schutz bietet

Drittländer können als Länder anerkannt werden, die ein angemessenes Schutzniveau für personenbezogene Daten gewährleisten, um die Übermittlung personenbezogener Daten aus EU- und EWR-Mitgliedstaaten in diese Länder zu ermöglichen.

Bislang hat die Europäische Kommission Andorra, Argentinien, Kanada (nur kommerzielle Organisationen), Südkorea, die Färöer, Guernsey, Israel, Isle of Man, Japan, Jersey, Neuseeland, die Schweiz, das Vereinigte Königreich, Uruguay und die Vereinigten Staaten (nur kommerzielle Organisationen, die am Datenschutzrahmen EU-USA teilnehmen) als Unternehmen anerkannt, die ein angemessenes Schutzniveau bieten (Stand 1. Januar 2023).

Diese Entscheidung hat zur Folge, dass personenbezogene Daten von EU- und EWR-Mitgliedstaaten in das betreffende Drittland (innerhalb des in jeder Entscheidung beschriebenen sachlichen Anwendungsbereichs) ohne zusätzliche Anforderungen übermittelt werden können.





Übermittlung in ein Drittland, das keinen angemessenen Schutz bietet

Für Datenverantwortliche oder Auftragsverarbeiter, die personenbezogene Daten in ein Land außerhalb des Europäischen Wirtschaftsraums übermitteln möchten, das nicht über ein angemessenes Schutzniveau verfügt, stehen verschiedene Garantien zur Verfügung.

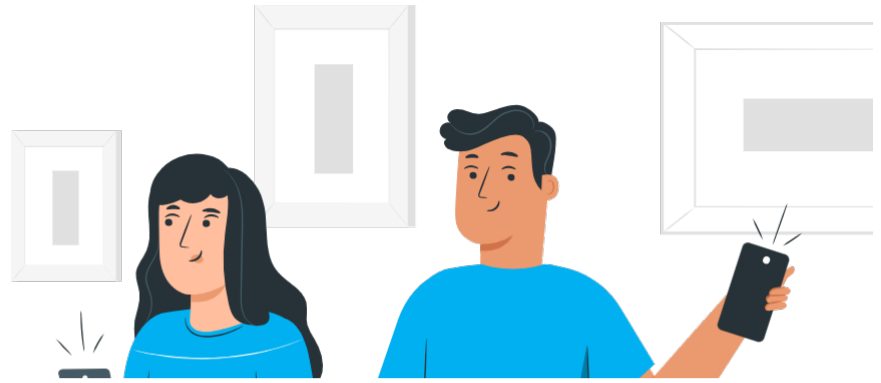
Verantwortliche und Auftragsverarbeiter können sich insbesondere auf die von der Europäischen Kommission adoptierten Standardvertragsklauseln (Standard Contract Clauses, SCCs) stützen, bei denen es sich um Musterverträge für die Übermittlung personenbezogener Daten handelt. Diese Standardvertragsklauseln wurden am 4. Juni 2021 aktualisiert und ersetzen die zuvor geltenden Standardvertragsklauseln. Sie unterscheiden sich von den SCCs für Beziehungen mit Auftragsverarbeitern. Dies sind die am besten geeigneten Garantien für kleine und mittlere Unternehmen.

Verbindliche interne Datenschutzvorschriften („binding corporate rules“ auf Englisch oder BCR) ermöglichen es, ein angemessenes Schutzniveau für Daten zu gewährleisten, die innerhalb und außerhalb des Europäischen Wirtschaftsraums innerhalb einer Unternehmensgruppe übermittelt werden. Diese angemessene Garantie eignet sich insbesondere für internationale Unternehmensgruppen, die

eine große Anzahl internationaler Datenübermittlungen durchführen.

Seit dem Inkrafttreten der DSGVO am 25. Mai 2018 stehen den für die Verarbeitung Verantwortlichen oder Auftragsverarbeitern, die personenbezogene Daten in ein Land außerhalb des Europäischen Wirtschaftsraums übermitteln möchten, das nicht über ein angemessenes Schutzniveau verfügt, neue Optionen zur Verfügung. Hierbei handelt es sich um:

- Verhaltensregeln, die gemäß Artikel 40 der DSGVO genehmigt wurden, zusammen mit einer verbindlichen und durchsetzbaren Verpflichtung des Verantwortlichen oder des Auftragsverarbeiters in dem Drittland, angemessene Garantien anzuwenden, auch in Bezug auf die Rechte der betroffenen Personen; und
- Zertifizierungsmechanismen genehmigt gemäß Artikel 42 der DSGVO, verbunden mit einer verbindlichen und durchsetzbaren Verpflichtung des Verantwortlichen oder des Auftragsverarbeiters in dem Drittland, angemessene Garantien anzuwenden, auch in Bezug auf die Rechte der betroffenen Personen.



DIE WICHTIGKEIT DES UNTER-AUFTRAGSVERTRAGS (Artikel 28 DSGVO)

Warum Datenuntervergabe regulieren?

Der Verantwortliche trägt die Gesamtverantwortung für den Schutz personenbezogener Daten, aber der Auftragsverarbeiter hat eine wichtige Rolle zu spielen, damit der Verantwortliche seinen Verpflichtungen nachkommen kann. Dazu gehört auch die Meldung von Verstößen.

Haftungsausschluss:

Dieses Dokument ist eine Zusammenfassung der Erläuterungen, die im Rahmen des DAAZ-Tools bereitgestellt werden, um die Antworten zu veranschaulichen. Der Inhalt dient nur zu Informationszwecken und sollte nicht als vollständige und erschöpfende Darstellung der diskutierten Themen ausgelegt werden. Die Inhalte unterliegen in keiner Weise der Verantwortung der CNPD. Im Falle eines Widerspruchs zwischen diesem Dokument und den auf der CNPD-Website veröffentlichten

Was sind die (nicht erschöpfenden) Pflichten der Auftragsverarbeiter?

- Verarbeitung personenbezogener Daten nur auf dokumentierte Anweisung des Verantwortlichen;
- Verarbeitung personenbezogener Daten nur für den/die spezifischen Zweck(e) der Verarbeitung;
- Durchführung technischer und organisatorischer Maßnahmen zur Gewährleistung der Sicherheit personenbezogener Daten;
- Mitarbeiterzugriff zu den personenbezogenen Daten, die Gegenstand der Verarbeitung sind, nur gewähren, soweit dies für die Erfüllung, Verwaltung und Überwachung des Vertrags unbedingt erforderlich ist;
- Sicherstellen, dass Personen, die zur Verarbeitung personenbezogener Daten befugt sind, sich zur Wahrung der Vertraulichkeit verpflichten;
- Anwendung spezifischer Beschränkungen und/oder zusätzlicher Garantien bei der Verarbeitung sensibler Daten;
- Schnelle und angemessene Bearbeitung von Anfragen des Verantwortlichen in Bezug auf die Verarbeitung von Daten;
- Prüfung der Verarbeitungstätigkeiten auf Antrag des Verantwortlichen zulassen;
- Nutzung der Dienste eines Unterauftragsverarbeiters zur Durchführung bestimmter Verarbeitungstätigkeiten nur mit vorheriger, spezifischer oder allgemeiner schriftlicher Genehmigung des Verantwortlichen. Unabhängig von der besonderen oder allgemeinen Art dieser Vorabgenehmigung muss der ursprüngliche Auftragsverarbeiter eine aktuelle Liste der anderen Unterauftragsverarbeiter führen.